



Análise de report de incidente.

Seguindo os padrões do NIST CSF (U.S National Institute of Standards and Technology - Cybersecurity framework), realizei uma análise a respeito de um report acerca de um ataque DoS realizado a uma empresa de marketing/Web design.

Sumario	Alterações abruptas e repentinas na latência rede interna foram notadas, após verificar a completa obstrução do tráfego normal da rede, confirmou-se a existência de um ataque cibernético. Devido a uma enxurrada de pacotes ICMP (ping flood) direcionados a rede, os serviços ficarem indisponíveis por cerca de duas horas. De imediato o time de resposta ao incidente bloqueou a entrada dos pacotes ICMP e interrompeu os serviços não essenciais e priorizou a restauração de serviços críticos. A investigação forense apontou que o alvo do ataque foi um firewall mal configurado que por sua vez redirecionou as requisições ICMP ping para a rede interna, caracterizando um ataque de negação de serviço (DoS).
Identificar	A vulnerabilidade principal foi identificada na configuração dos ativos de segurança: um firewall de borda não estava configurado corretamente para filtrar tráfego ICMP excessivo. A auditoria pós-incidente revelou a necessidade de catalogar e revisar as configurações de todos os dispositivos de segurança da rede para garantir que não haja outras lacunas de conformidade ou ativos expostos a riscos similares.

Proteger	Após o ataque ser repreendido e audiências serem realizadas, a equipe de segurança de rede implementou medidas para reduzir o risco de ataques parecidos e mais complexos (Hardening da rede), as medidas foram: Limitação de pacotes ICMP no firewall, verificação de endereços de IP falsos enviados nos pacotes ICMP, implementação de software de monitoramento de rede (SIEM) e adoção de um sistema IDS/IPS para reconhecer comportamentos futuros parecidos e suspeitos, os interceptando antes de atingirem a rede interna.
Detectar	Para monitoramento futuro e aumento da visibilidade, o time adotou ferramentas como firewall configurado, ferramentas de monitoramento SIEM e adoção de dispositivos IDS/IPS que irão servir para notificar comportamentos estranhos e interceptar tráfego.
Responder	O time de resposta conteve a entrada de pacotes e agilmente mitigou os danos (isolamento dos serviços). Após as medidas serem tomadas nos firewalls, os clientes foram notificados do acontecimento e assegurados da segurança implementada para manutenção da continuidade dos negócios.
Recuperar	Os sistemas críticos foram restaurados e estabilizados imediatamente. Os serviços não críticos foram recuperados para o estado anterior ao ataque através de backups íntegros. A configuração corrigida do firewall foi estabelecida como o novo padrão.

Reflexões/notas: Nota-se a importância da manutenção constante e da revisão da situação dos dispositivos da empresa, um ataque flood de pings ICMP é considerado simples e obsoleto hodiernamente, o que demonstrou uma ausência de meticulosidade quando se trata da configuração de certos equipamentos. A ausência de alertas prévios reforçou a urgência na implementação de camadas de detecção mais robustas para prevenir futuros incidentes.